COMPLIANCE & SECURITY · CHECKLIST

Security Questionnaire Readiness Checklist

For revenue and operations leaders who need to respond to customer security reviews quickly and consistently instead of scrambling deal by deal.

> **How to use this:** Draft a standing answer for each item below, store it in one shared location, and update it whenever a practice changes. The AI section is now the one buyers ask about most often.

Data and Access Fundamentals

- [ ] Where is customer data hosted, and in which regions?
- [ ] Who inside the company can access customer data, and how is that access controlled?
- [ ] How is customer data encrypted, both in transit and at rest?
- [ ] What is the process for provisioning and removing employee access to systems holding customer data?
- [ ] Is multi-factor authentication required for production and customer data, and is it phishing-resistant for admins?

Vendors, Subprocessors, and Data Flow

- [ ] What third-party tools or subprocessors touch customer data, and for what purpose?
- [ ] Is there a current subprocessor list, including AI model providers, that can be shared on request?
- [ ] Are subprocessor agreements in place that require equivalent data protection standards?
- [ ] Is customer data ever used for purposes beyond delivering the product (for example model training or analytics)?

AI and Model Use

Expect these in most enterprise reviews from now on, often as a separate AI addendum.

- [ ] Which AI features does the product include, and which model providers power them?
- [ ] Is customer data, including prompts and outputs, used to train or improve any model? Where is that stated in the contract?
- [ ] How long are prompts, outputs and logs retained, where, and who can access them?
- [ ] Can customers switch AI features off, or choose which data they can reach?
- [ ] What human oversight applies to AI outputs that affect customers or their end users?
- [ ] How are AI features tested before release and monitored afterwards, including for prompt injection and data leakage?
- [ ] Does any feature make or substantially inform decisions about individuals? Customers covered by Australia's Privacy Act will need this for their own privacy policies from 10 December 2026.

© 2026 Rev-IQ. Free to use and adapt.

- [ ] Who owns AI governance internally, and is there a written AI policy you can share?

Continuity, Backup, and Incident Response

- [ ] How often is customer data backed up, and how is a restore tested?
- [ ] What is the process if a security incident or data exposure is suspected?
- [ ] What notification timeframe do we commit to customers, and does it fit the regulatory clocks they work to?
- [ ] What is the disaster recovery plan if core infrastructure becomes unavailable?

Certifications and Formal Frameworks

Do we hold any certifications or attestations (SOC 2, ISO/IEC 27001, ISO/IEC 42001)? If not, what's the honest plan and timeline?

Have we completed a third-party penetration test or security audit? When, and what changed as a result?

What is our accurate, agreed answer when a customer asks for a certification we don't yet hold?

Standards Buyers Map You Against

Questionnaire or standard	What it tells you about the buyer
SIG (Shared Assessments) or CAIQ (Cloud Security Alliance)	A formal third-party risk program. Answer once in full and reuse.
Questions numbered against ISO/IEC 27001 Annex A	The buyer is certified or working towards it and will map your answers to its controls.
Questions grouped as SOC 2 trust services criteria	A US-style audit lens. A SOC 2 report may replace most of the questionnaire.
An AI addendum or questions on ISO/IEC 42001 or the NIST AI RMF	The buyer has an AI governance function. Have your AI policy and AI register ready.

© 2026 Rev-IQ. Free to use and adapt.

Readiness Tracker

Question category	Answer ready? (Y / N)	Owner	Last updated
Data hosting and encryption			
Access control			
Subprocessors and vendors			
AI and model use			
Backup and continuity			
Incident response			
Certifications			

General guidance, not legal advice. References to standards show where this resource aligns; using it does not make an organisation compliant or certified. Check your specific obligations with a qualified adviser. Regulatory references checked October 2026.

© 2026 Rev-IQ. Free to use and adapt.